

Wisec - The Wise SECurity

Wisec - The Wise SECurity - Author not stated, wisec.it.

- Published: date not stated
- Original: <<http://www.wisec.it/sectou.php?id=4706611fe9210>>
- Preserved from: <http://www.wisec.it/sectou.php?id=4706611fe9210> (live) on 2026-08-09
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Wisec - The Wise SECurity

THP [Wisec](#) [USH](#) [DigitalBullets](#) [TheHackersPlace](#) network

|

!

The ***WI*se *SEC*urity**

| [.italian](#) [.english](#) | |

[Wisec Home](#) [SecSearch](#) [Projects](#) [Papers](#) [Security Thoughts](#)

| [News](#)

[Flash Application Testing: A New Vector for XSS and Cross Site Flashing.](#)

[IE and Firefox Digest Authentication Request Splitting.](#)

[Php import_req_var globals overwrite Advisory.](#)

[Subverting Ajax - The Paper.](#)

[Adobe Plugin Multiple Vulnerabilities.](#)

[Wisec@23rd.CCC Congress in Berlin - 29th Dec. 2006 - Subverting Ajax.](#)

[SecSearch. Search Engine for Security Community.](#)

[Mysql COM_TABLE_DUMP Flaws.](#)

[Mysql Anonymous login Flaw.](#)

[A new project to stop embed passwords in Php scripts: PassBroker.](#)

[MySQL new three vulnerabilities unleashed](#)

[PHP shmop safemode bypass](#)

Security Thoughts

[Back]

Friday, October 05, 2007, 17:47

Optimizing the number of requests in blind SQL injection

Blind injection is often considered as an On/Off binary research accomplished using the bisection algorithm. When the bisection algorithm is applied the complexity is $O(\log_2 n)$ where n is in the case of the extended ASCII character set is 255. So for each character at a given position 'p' the total number of requests will be:

$$\log_2 n = \log_2 255 \approx 7$$

So if the length of the information to be retrieved is 8, the total number of requests to be sent is $8 * \log_2 255 = 56$

Let's suppose now, there is the following situation:

http://vi.ctim/page.jsp?id=1

where page.jsp is a script which loads dynamically content by using the SQL query:

```
qry= "Select content from pages where id="+Request.value("id");
```

Let's suppose the rest of the application gives no clue about SQL errors or the possibility to use other tricks in order to force the web application to display the informations we want. This is a classical Blind SQL Injection case.

But what happens if by changing 'id' values results displaying different pages?

The attacker could use the different responses in order to map the results of an injected conditional sql statement.

That is. Let's suppose there are more than 255 values for the 'id' parameter

```
"http://vi.ctim/page.jsp?id=1" "http://vi.ctim/page.jsp?id=2" ... "http://vi.ctim/page.jsp?id=255"
```

then let's map every single snippet of unique text content for every request. Then by setting

```
For (pos = 1; pos < LEN(@@version)){ idval="(CASE substr(@@version,"+pos+",1) when char(1) then 1  
when char(2) then 2 when char(3) then 3 when char(4) then 4 when char(4) then 5 etc end )" get  
response for: "http://vi.ctim/page.jsp?id=idval" }
```

the attacker will have to accomplish only

LEN(@@version)

requests, because for every request the application will return the page mapped to the character value.

Now, this is the best case. For every character value exists a single id value.

There could be a number of id values which is less than 255 (or # printable chars for non binary information).

Let's suppose there exist only 4 unique id values corresponding to 4 unique responses. Then the injected query will be (in pseudo code):

```
res=substr(@@version,pos,1);
```

```
if(res>191 and res<255) then 1 else if(res>127 and res<192) then 2 else if(res>63 and res<128) then 3 else 4
```

For each result, the set of values we are analysing will be 1/4 of the previous set.

This algorithm has $O(\log_4 255)$, which will correspond to

$$\mathbf{LEN * \log_4 255 = LEN * 3.9}$$

requests to be sent.

The worst case is the On/Off bisection algorithm already described in several papers.

I don't have the time to implement it now, but I hope to see some tool with this (maybe) new approach in it:)

Wisec, Tuesday, October 09, 2007, 00:20

Bedirhan Urgun, Tuesday, October 09, 2007, 15:54

Wisec, Tuesday, October 09, 2007, 16:27

* *Bedirhan Urgun* *, Tuesday, October 09, 2007, 19:29

Wisec, Tuesday, October 09, 2007, 19:38

Wisec, Tuesday, October 09, 2007, 19:43

* *Bedirhan Urgun* *, Wednesday, October 10, 2007, 07:50

* *Bernardo Damele* *, Thursday, October 11, 2007, 15:43

Comments are disabled

[Admin login](#) | This weblog is from www.mylittlehomepage.net

Wisec is brought to you by...

Wisec is written and mantained by Stefano Di Paola.

Wisec uses open standards, including XHTML, CSS2, and XML-RPC.

| |

